

Gruppenaufgabe 2

Risikomatrix und Risikoklassifizierung

Szenario

Die «AlpinTech GmbH», ein mittelständisches Produktionsunternehmen in Bern, plant die Einführung eines systematischen Risikomanagements für ihre IT-Infrastruktur. Bisher wurden Risiken nur informell und ohne einheitliche Methodik bewertet. Als internes Analyseteam sollen Sie eine Risikomatrix für die fünf grössten Bedrohungen der Datensicherung erstellen und daraus konkrete Steuerungsmassnahmen ableiten.

Lernziele

Nach Bearbeitung dieser Aufgabe können Sie:

- Risiken anhand von Eintrittswahrscheinlichkeit und Schadensausmass in einer Risikomatrix klassifizieren und einordnen.
- Geeignete Risikosteuerungsmassnahmen (Vermeidung, Minderung, Transfer, Akzeptanz) bewerten und begründet zuordnen.
- Die Ergebnisse einer Risikobewertung für das Management verständlich aufbereiten und präsentieren.

Arbeitsauftrag

Identifizieren Sie in Ihrer Kleingruppe die fünf grössten Risiken für die Datensicherung der «AlpinTech GmbH». Bewerten Sie jedes Risiko hinsichtlich Eintrittswahrscheinlichkeit (1–5) und Schadensausmass (1–5), tragen Sie die Risiken in eine Risikomatrix ein und ordnen Sie jedem Risiko eine Steuerungsmassnahme zu.

Ergebnis

Bereiten Sie eine Kurzpräsentation vor (max. 5 Minuten), in der Sie Ihre ausgefüllte Risikomatrix zeigen und die gewählten Steuerungsmassnahmen für die drei kritischsten Risiken begründen.

Musterlösung A | Gruppenaufgabe 2 | Risikomatrix und Risikoklassifizierung

Ansatz: Strukturiert-analytisch

1. Methodik und Bewertungsskala

Für die Risikobewertung der AlpinTech GmbH verwenden wir eine 5×5-Risikomatrix mit folgenden Skalen:

Eintrittswahrscheinlichkeit (EW):

Stufe	Bezeichnung	Beschreibung
1	Sehr unwahrscheinlich	Weniger als einmal in 10 Jahren
2	Unwahrscheinlich	Einmal in 5–10 Jahren
3	Möglich	Einmal in 1–5 Jahren
4	Wahrscheinlich	Einmal pro Jahr
5	Sehr wahrscheinlich	Mehrmals pro Jahr

Schadensausmass (SA):

Stufe	Bezeichnung	Beschreibung
1	Geringfügig	Kein nennenswerter Schaden, schnell behebbar
2	Gering	Kleinere Beeinträchtigung, Behebung innerhalb Stunden
3	Moderat	Spürbare Beeinträchtigung, Behebung innerhalb Tagen
4	Erheblich	Schwere Beeinträchtigung, hoher finanzieller Schaden
5	Katastrophal	Existenzbedrohend, Totalverlust möglich

Risikowert (RW): $EW \times SA$. Kategorisierung: 1–5 = Grün (gering), 6–12 = Gelb (mittel), 13–19 = Orange (hoch), 20–25 = Rot (kritisch).

2. Identifikation und Bewertung der Top-5-Risiken

Nr.	Risiko	EW	SA	RW	Farbe
R1	Ransomware-Angriff	4	5	20	Rot
R2	Hardwareausfall Backup-Server	3	4	12	Gelb
R3	Menschlicher Bedienfehler	4	3	12	Gelb
R4	Fehlende Restore-Tests	5	4	20	Rot
R5	Stromausfall ohne USV	2	4	8	Gelb

3. Darstellung in der Risikomatrix

gherkin

Schadensausmass →						
		1	2	3	4	5
EW 5					R4	
4				R3		R1
3				R2		
2				R5		
1						

4. Steuerungsmassnahmen

R1 – Ransomware-Angriff (Rot, RW 20) → Risikominderung:

Die AlpinTech GmbH muss zwingend ein mehrstufiges Schutzkonzept implementieren. Dazu gehören: Offline-Backup (Air-Gap), Endpoint-Protection mit Ransomware-Erkennung, regelmässige Mitarbeiterschulungen zu Phishing und ein spezifischer Ransomware-Notfallplan. Diese Kombination aus technischen und organisatorischen Massnahmen reduziert sowohl die Eintrittswahrscheinlichkeit als auch das Schadensausmass.

R4 – Fehlende Restore-Tests (Rot, RW 20) → Risikominderung:

Monatliche Restore-Tests müssen als verbindlicher Prozess eingeführt werden. Dabei wird mindestens ein kritisches System vollständig wiederhergestellt und das Ergebnis protokolliert. Zusätzlich sollte halbjährlich ein vollständiger Disaster-Recovery-Test

durchgeführt werden. Die Verantwortlichkeit liegt beim IT-Leiter, die Ergebnisse werden dem Management quartalsweise rapportiert.

R3 – Menschlicher Bedienfehler (Gelb, RW 12) → Risikominderung:

Einführung eines Vier-Augen-Prinzips bei kritischen Backup-Konfigurationsänderungen, Automatisierung wiederkehrender manueller Aufgaben und regelmässige Schulungen für alle IT-Mitarbeitenden. Zusätzlich sollten Backup-Jobs so konfiguriert werden, dass manuelle Eingriffe auf ein Minimum reduziert werden.

R2 – Hardwareausfall (Gelb, RW 12) → Risikominderung + Transfer:

Einsatz redundanter Backup-Systeme (z. B. zwei unabhängige Backup-Server) und Abschluss eines Wartungsvertrags mit garantierten Reaktionszeiten (SLA). Zusätzlich kann das Restrisiko durch eine Cyberversicherung teilweise auf den Versicherer transferiert werden.

R5 – Stromausfall (Gelb, RW 8) → Risikoakzeptanz + Minderung:

Da die Eintrittswahrscheinlichkeit gering ist, kann ein Restrisiko akzeptiert werden. Dennoch sollte eine USV-Anlage installiert werden, die mindestens die Dauer des Backup-Fensters abdeckt. Dies ist eine kostengünstige Massnahme mit hohem Schutzeffekt.

5. Zusammenfassung und Empfehlung ans Management

Die Analyse zeigt zwei kritische Risiken (Rot): Ransomware und fehlende Restore-Tests. Beide erfordern sofortiges Handeln. Die drei gelben Risiken sollten im Rahmen eines Quartalsplans adressiert werden. Die Risikomatrix sollte halbjährlich aktualisiert werden, um neue Bedrohungen frühzeitig zu erkennen.

Musterlösung B | Gruppenaufgabe 2 | Risikomatrix und Risikoklassifizierung

Ansatz: Praxisnah-narrativ

1. Die Ausgangslage bei AlpinTech: Risikomanagement im Blindflug

Die AlpinTech GmbH ist ein typisches mittelständisches Schweizer Produktionsunternehmen. Die IT-Abteilung besteht aus fünf Personen, die neben dem Tagesgeschäft auch die Datensicherung betreuen. Bisher gab es kein formales Risikomanagement – Risiken wurden «nach Gefühl» eingeschätzt. Das soll sich jetzt ändern. Aber wie geht man vor, wenn man zum ersten Mal eine Risikomatrix erstellen soll?

2. Schritt 1: Was kann uns wirklich treffen?

Beginnen wir mit einem Brainstorming im Team. Wir stellen uns die Frage: «Was sind die fünf Dinge, die unserer Datensicherung am meisten schaden könnten?» Nach einer offenen Diskussion kristallisieren sich folgende Risiken heraus:

1. **Ransomware-Angriff:** Wir haben in den Medien immer wieder von Schweizer KMU gelesen, die von Ransomware betroffen waren. Als Produktionsunternehmen mit zunehmender Digitalisierung (IoT-Sensoren, ERP-System, CAD-Daten) wären wir ein lohnendes Ziel.
2. **Niemand testet unsere Backups:** Ehrlich gesagt – wir haben seit über einem Jahr keinen Restore-Test gemacht. Wir sichern jede Nacht, aber ob die Daten wirklich wiederherstellbar sind, wissen wir schlicht nicht.
3. **Fehlbedienung durch Mitarbeitende:** Letzten Monat hat ein Kollege versehentlich eine komplette Projektablage überschrieben. Das Backup hatte die Daten zum Glück noch, aber was, wenn nicht?
4. **Der Backup-Server ist ein Single Point of Failure:** Wir haben genau einen Backup-Server. Fällt der aus, haben wir kein Backup mehr, bis er repariert oder ersetzt ist.
5. **Stromausfall:** Unser Serverraum hat eine USV, aber die wurde seit der Installation vor drei Jahren nie gewartet oder getestet. Ob sie im Ernstfall noch funktioniert, ist fraglich.

3. Schritt 2: Wie wahrscheinlich ist das, und wie schlimm wäre es?

Jetzt müssen wir jedes Risiko bewerten. Dafür verwenden wir eine einfache Skala von 1 (sehr gering) bis 5 (sehr hoch) für Eintrittswahrscheinlichkeit und Schadensausmass.

Ransomware: Die Wahrscheinlichkeit ist hoch (4/5) – wir hören ständig von Fällen, und unsere E-Mail-Sicherheit ist nur mittelmässig. Das Schadensausmass wäre katastrophal (5/5) – wenn alle Daten verschlüsselt werden, steht die Produktion still. **Risikowert: 20 – ROT.**

Keine Restore-Tests: Die Wahrscheinlichkeit, dass unser Backup im Ernstfall nicht funktioniert, ist erschreckend hoch (5/5), weil wir es schlicht nicht wissen. Das Schadensausmass ist erheblich (4/5) – wenn das Backup versagt, haben wir dasselbe Problem wie ohne Backup. **Risikowert: 20 – ROT.**

Fehlbedienung: Kommt regelmässig vor (4/5). Der Schaden ist meist moderat (3/5), weil einzelne Dateien betroffen sind, nicht ganze Systeme. **Risikowert: 12 – GELB.**

Backup-Server-Ausfall: Möglich (3/5) – der Server ist drei Jahre alt, und Hardwareausfälle kommen vor. Der Schaden wäre erheblich (4/5), weil wir ohne Backup-Server keine Sicherungen mehr erstellen können. **Risikowert: 12 – GELB.**

Stromausfall: Eher unwahrscheinlich (2/5) in Bern, aber nicht ausgeschlossen. Der Schaden wäre erheblich (4/5), falls ein Backup gerade läuft. **Risikowert: 8 – GELB.**

4. Schritt 3: Was tun wir dagegen?

Jetzt kommt der wichtigste Teil: Aus der Bewertung Massnahmen ableiten. Und zwar nicht theoretische, sondern solche, die wir bei der AlpinTech GmbH realistisch umsetzen können.

Gegen Ransomware (ROT): Wir brauchen drei Dinge. Erstens: Ein Offline-Backup, das nicht im Netzwerk hängt. Das kann eine externe Festplatte sein, die jeden Freitag manuell bespielt und im Tresor gelagert wird – einfach und effektiv. Zweitens: Eine bessere E-Mail-Filterung, weil die meisten Ransomware-Angriffe über Phishing-E-Mails kommen. Drittens: Eine Schulung für alle Mitarbeitenden, wie man verdächtige E-Mails erkennt. Die Massnahmenart ist «Risikominderung» – wir können Ransomware nicht verhindern, aber wir können die Wahrscheinlichkeit und die Auswirkungen deutlich reduzieren.

Gegen fehlende Restore-Tests (ROT): Ab sofort führen wir jeden ersten Montag im Monat einen Restore-Test durch. Der IT-Leiter ist verantwortlich. Wir erstellen ein einfaches Protokollformular und starten mit der Wiederherstellung unseres ERP-Systems, weil das unser kritischstes System ist. Das ist «Risikominderung» – wir senken die Wahrscheinlichkeit, dass ein defektes Backup unentdeckt bleibt, von 5 auf idealerweise 1.

Gegen Fehlbedienung (GELB): Wir richten ein automatisiertes Versionierungssystem ein, sodass überschriebene Dateien nicht sofort verloren sind. Das reduziert den Schaden von 3 auf 1 und macht aus einem gelben ein grünes Risiko. Zusätzlich schulen wir die Mitarbeitenden im korrekten Umgang mit der Dateiablage.

5. Präsentation fürs Management

Wenn wir diese Ergebnisse dem Management präsentieren, müssen wir es einfach halten. Wir zeigen die farbige Risikomatrix – Rot springt sofort ins Auge – und erklären in drei

Sätzen pro rotem Risiko, was wir tun wollen, was es kostet und bis wann es umgesetzt sein wird. Führungskräfte wollen keine technischen Details, sondern Klarheit: Wo stehen wir, und was müssen wir tun?

Die Kernbotschaft lautet: «Wir haben zwei kritische Risiken identifiziert. Die Massnahmen sind klar, realistisch und können innerhalb von drei Monaten umgesetzt werden. Das Budget beträgt schätzungsweise CHF 15 000 für die Offline-Backup-Lösung und die verbesserte E-Mail-Sicherheit.»

6. Fazit

Die Risikomatrix ist kein akademisches Instrument – sie ist ein praktisches Werkzeug, das der AlpinTech GmbH hilft, begrenzte Ressourcen dort einzusetzen, wo sie am meisten Wirkung erzielen. Die zwei roten Risiken erfordern sofortiges Handeln, die gelben werden im Quartalsrhythmus angegangen. Das Wichtigste dabei: Die Matrix lebt und muss regelmässig aktualisiert werden.